

1. Purpose

This document aims to outline the objectives of the ISMS metrics for PrimeHealth Clinic & Diagnostics. We gather, measure, and assess security metrics to track and improve the effectiveness of our information security controls. These metrics aid in decision-making, drive continuous improvement, and ensure compliance with security standards, demonstrating our commitment to protecting information assets. ISMS metrics are reviewed regularly, both on designated days and whenever an executive raises a concern or initiates a discussion regarding the metrics.

2. Scope

The scope of this process documentation applies to all departments and stakeholders within the company. It also includes services, business processes, IT systems, information assets, and all other factors that can affect our information security.

Information assets, processes, systems, locations, or personnel that are not directly associated with the C-level executive roles or their departments have been specifically declared out of the scope of this document. Additionally, departments or roles that are not part of the top management team and their corresponding assets and processes are excluded from the scope.

3. Metrics Categories:

3.1. Security Risk Metrics

- Objective: Measure potential threats and vulnerabilities affecting information assets.
- Examples:
 - Number of identified security incidents.
 - Number of critical vulnerabilities identified.
 - Average time to detect/respond to security incidents.

3.2. Security Control Effectiveness

- Objective: Assess how well security controls are performing in protecting information.
- Examples:
 - Percentage of controls implemented and tested.
 - Number of non-conformities found in security audits.
 - Percentage of staff completing security awareness training.

3.3. ISMS Compliance Metrics

- Objective: Track adherence to ISO/IEC 27001 requirements and policies.
- Examples:
 - Number of compliance deviations detected.
 - Percentage of completed internal and external audits.
 - Frequency of ISMS policy updates.

3.4. Operational Metrics

- Objective: Monitor the operational aspects of the ISMS.
- Examples:
 - Downtime due to security incidents.
 - System availability percentage.
 - Time to remediate critical security issues.

4. Evidence Collection and Reporting

4.1. Metric Reporting

- Security metrics will be reported via various platforms including:
 - Reports: Monthly/quarterly ISMS security reports.
 - Dashboards: Real-time security metrics on internal dashboards.
 - Presentations: Quarterly executive presentations summarizing ISMS performance.

4.2. Evidence of Action

- Evidence that metrics are being reviewed and acted upon includes:
 - Memos/Emails: Highlighting concerns about security incidents or trends.
 - Printed Reports: Handwritten comments from executives on printed security reports.
 - Meeting Minutes: Documenting discussions and actions taken based on metric trends.
 - Action Plans: Formal plans created to address identified risks or weaknesses.
 - Internal Communications: Rough notes, emails, or meeting summaries indicating response to both positive and adverse security trends.

5. Metrics Review Process

Metrics are reviewed at various intervals:

- Scheduled Reviews: Metrics are assessed on predetermined review dates (e.g., monthly or quarterly).
- Ad-Hoc Reviews: Executives or department heads can initiate a review whenever an issue or concern arises.

6. Responsibilities

- CSO/CRO: Responsible for overseeing the collection and reporting of security metrics.
- Executive Team: Reviews the security metrics and acts on findings.
- Department Heads: Monitor and ensure metrics within their departments are in line with the overall ISMS objectives.